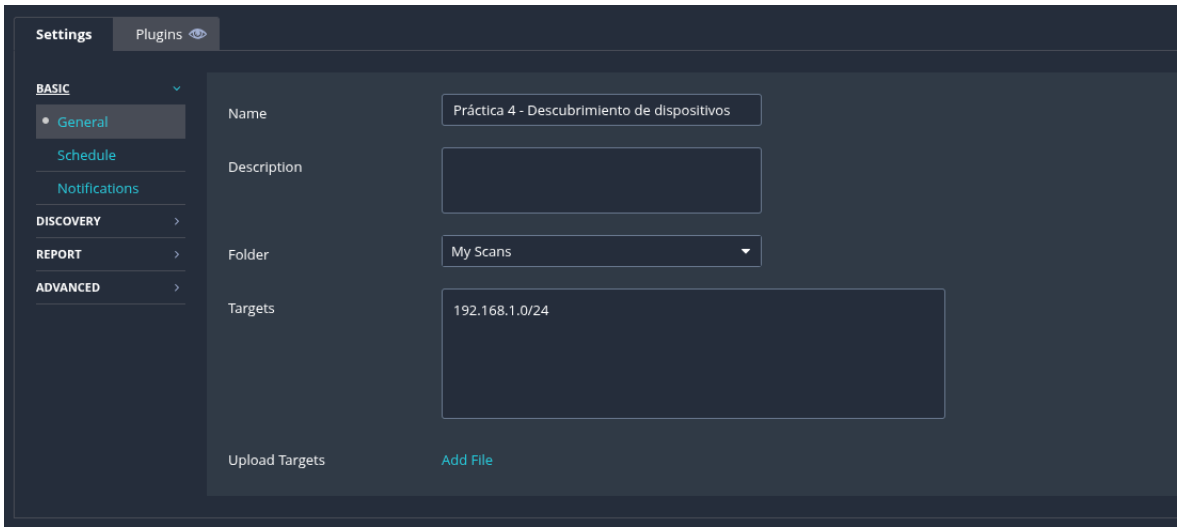


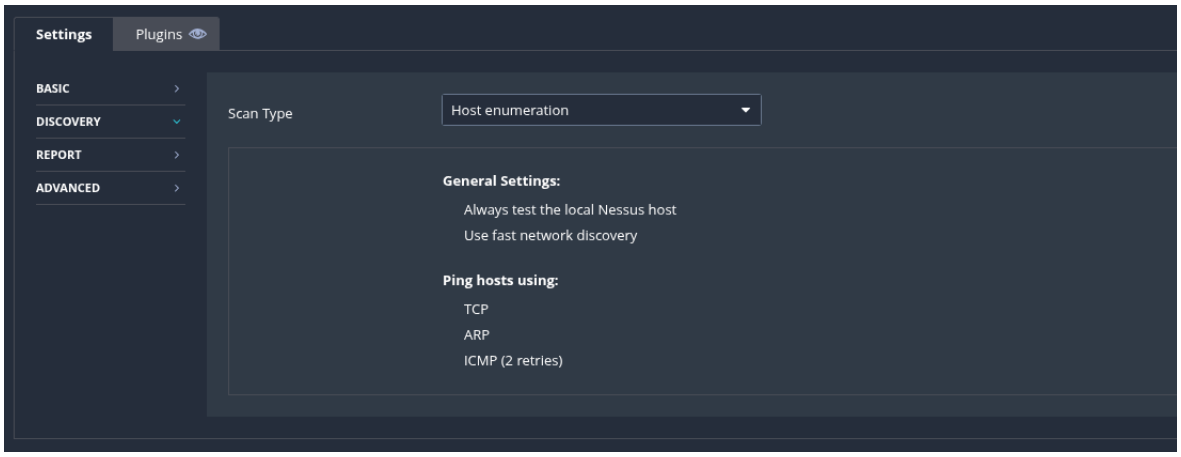
Universidad Nacional Autónoma de México
Facultad de Ciencias
Criptografía y Seguridad
Práctica 4
Domínguez Sánchez Gustavo Alonso
418047121

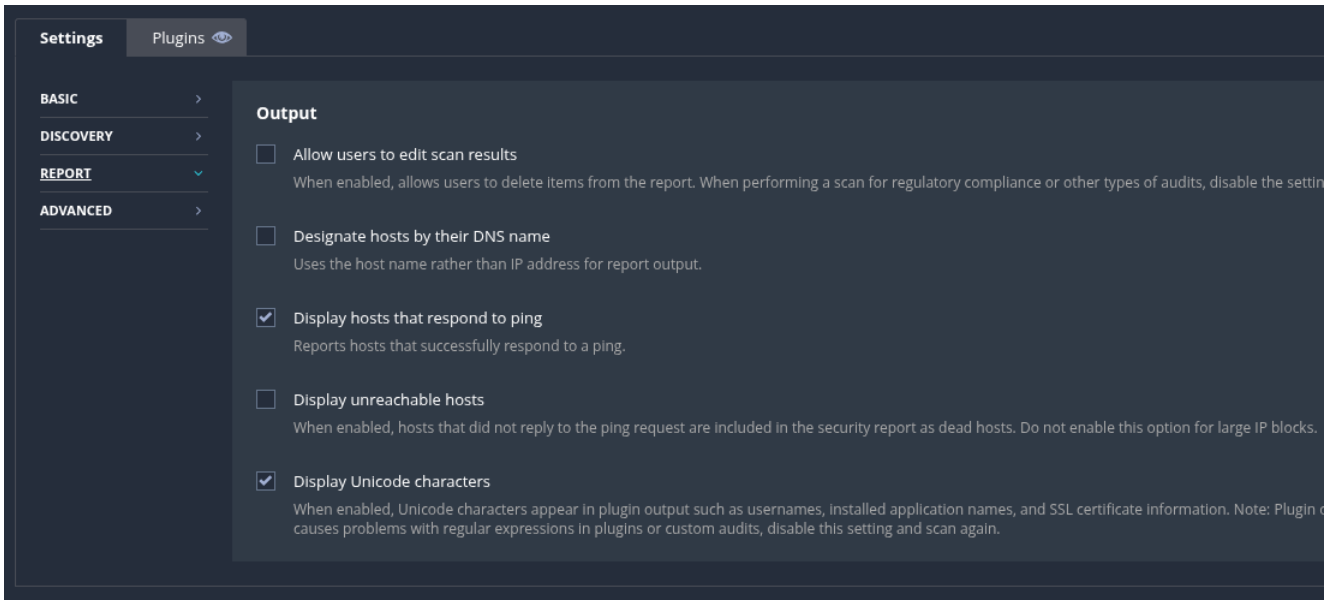


1. Host Recovery: Descubrimiento de dispositivos

Con ayuda de Nessus, se realizó un escaneo rápido de puertos (*Host Recovery*), con la siguiente configuración:







El reporte nos muestra los siguientes puertos:

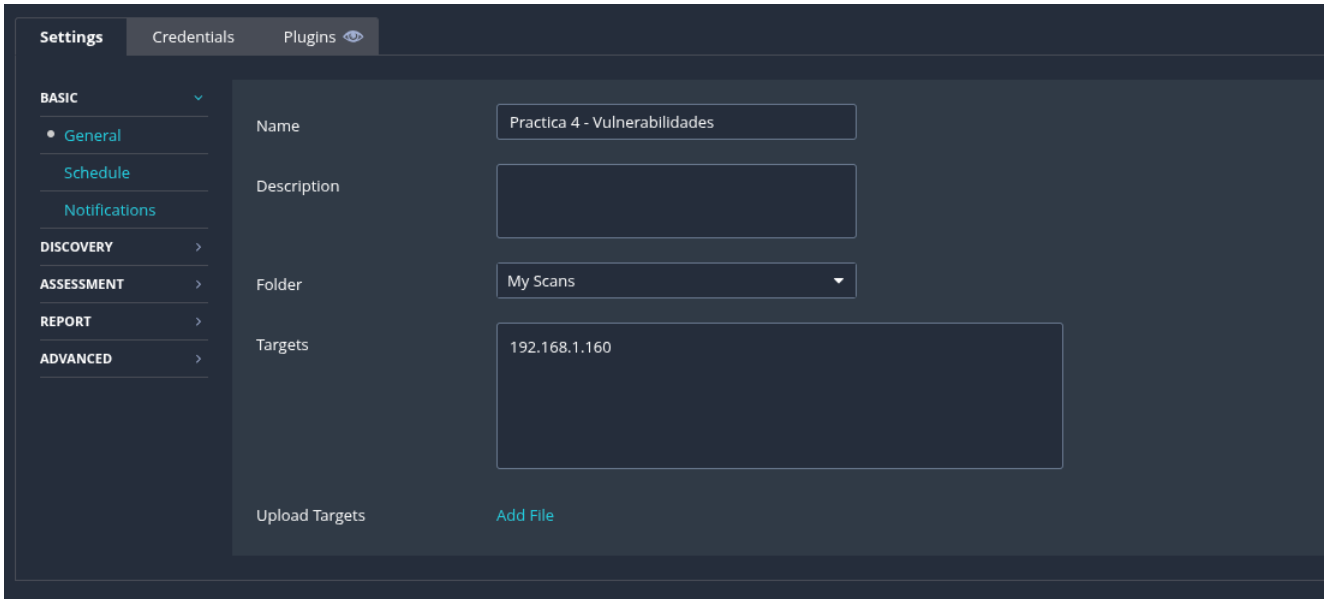
- 192.168.1.65
- 192.168.1.67
- 192.168.1.68
- 192.168.1.113
- 192.168.1.160 (mi dispositivo)
- 192.168.1.254

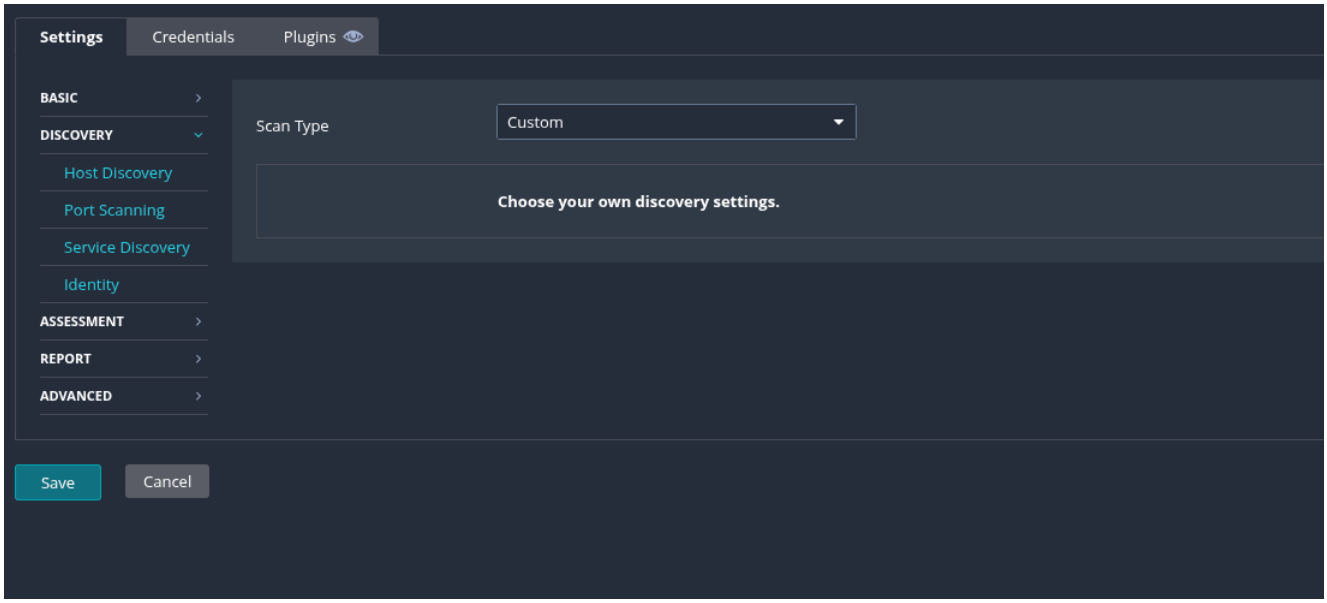
Los resultados detallados de este escaneo se encuentran en el archivo `Descubrimiento de Dispositivos.pdf`

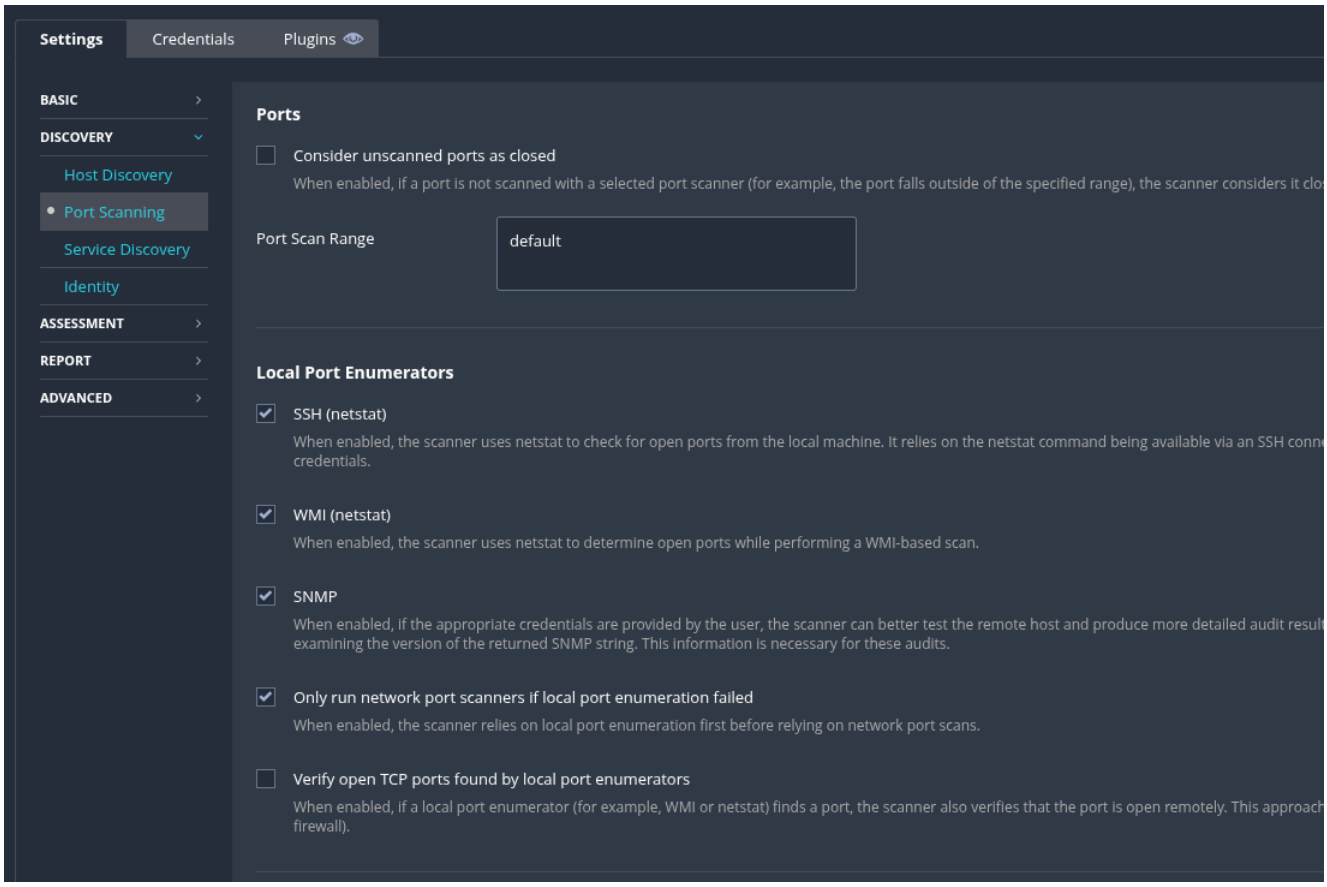
2. Basic Network Scan: Descubrimiento de vulnerabilidades

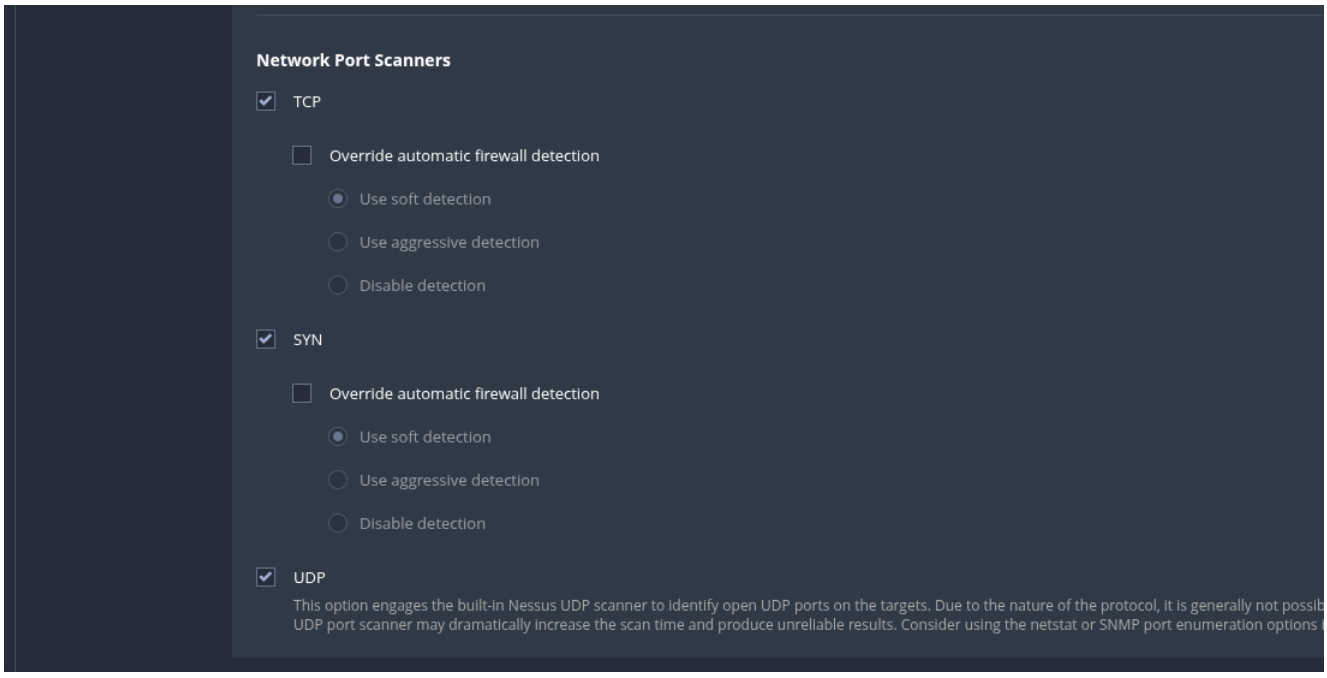
2.1. Primer escaneo

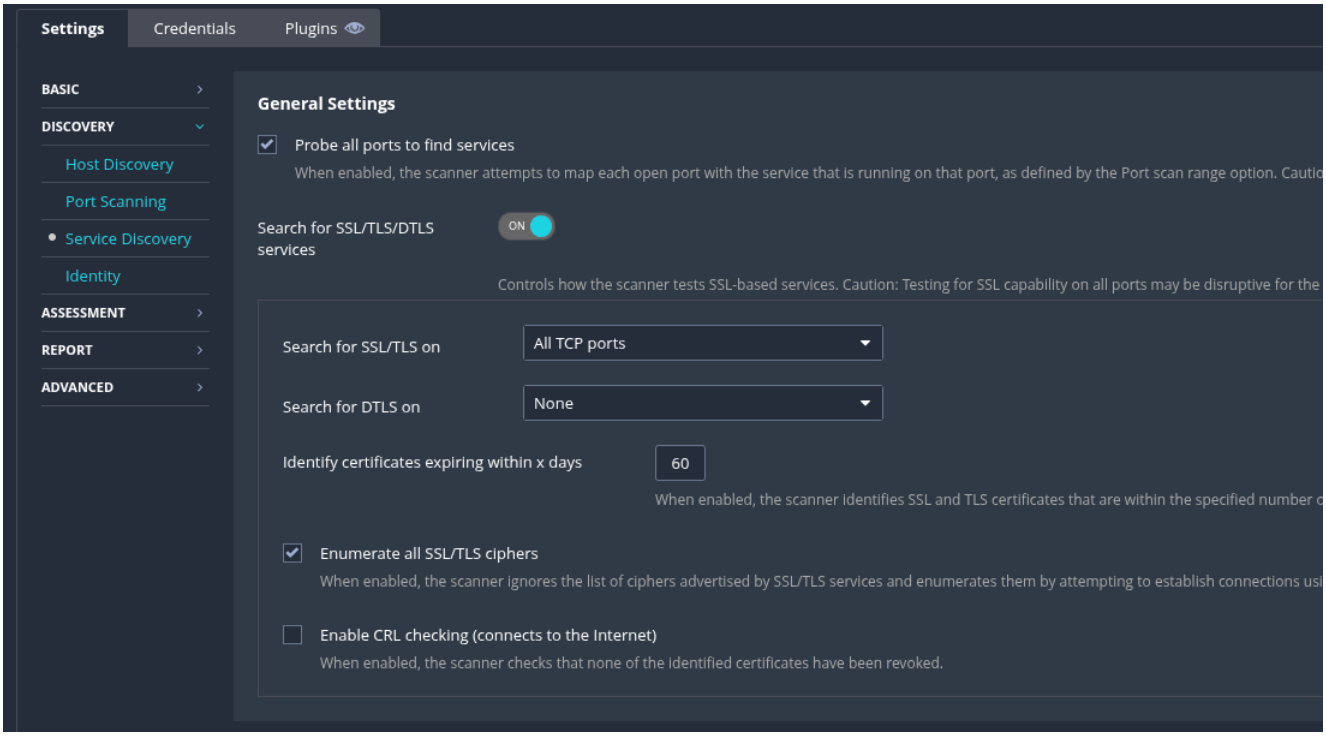
Con la opción *Basic Network Scan*, realizaremos un escaneo a mi equipo personal (192.168.1.160). Los parámetros del escaneo son los siguientes:

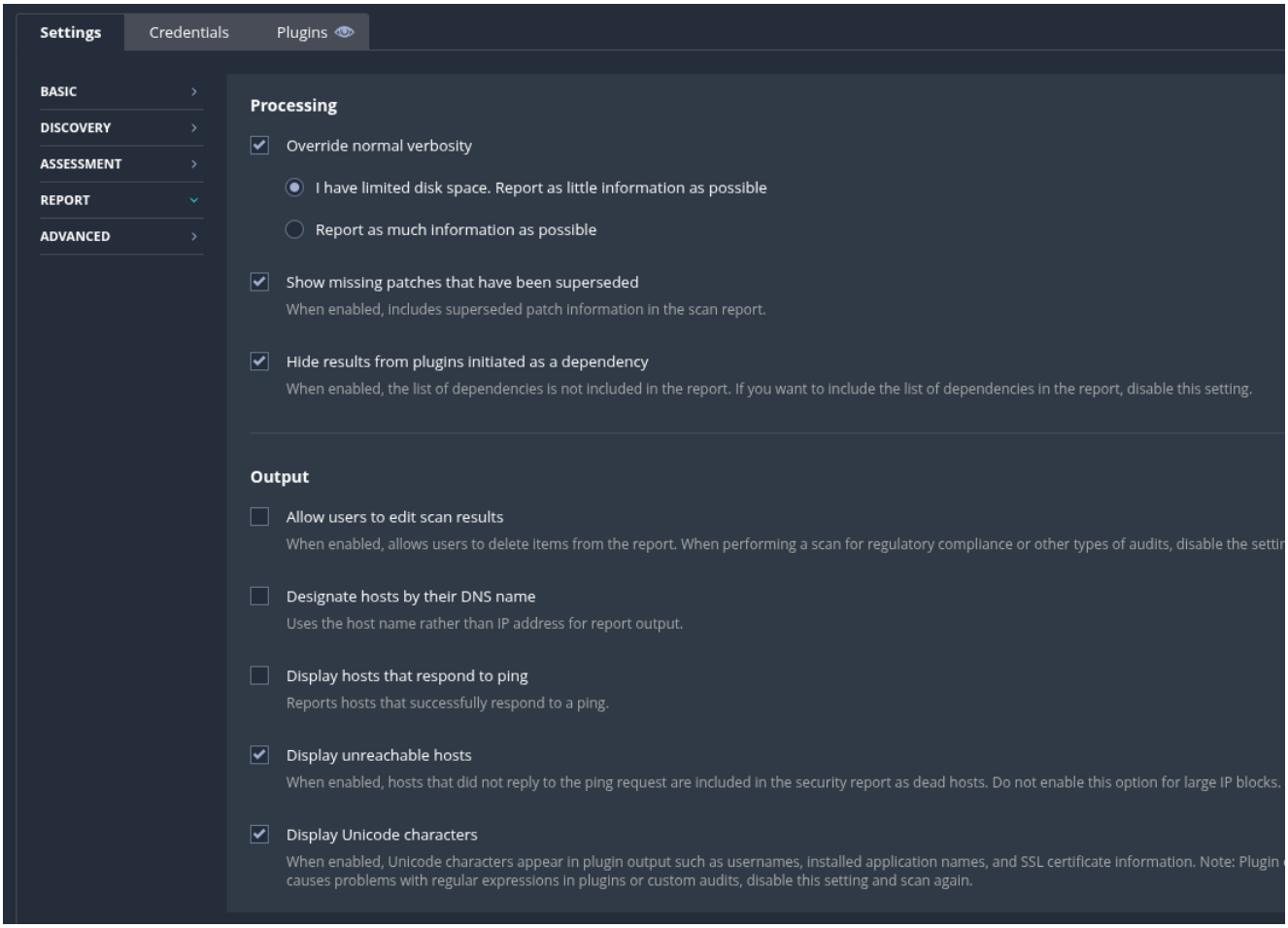


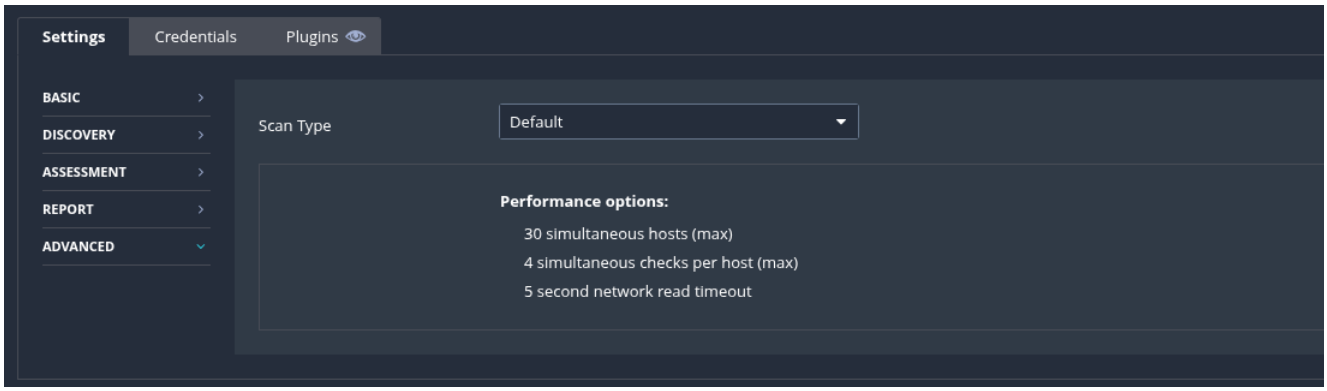



Settings
Credentials
Plugins
BASIC
DISCOVERY
Host Discovery
Port Scanning
Service Discovery
Identity
ASSESSMENT
REPORT
ADVANCED
Ports
Consider unscanned ports as closed
When enabled, if a port is not scanned with a selected port scanner (for example, the port falls outside of the specified range), the scanner considers it clo
Port Scan Range
default
Local Port Enumerators
SSH (netstat)
When enabled, the scanner uses netstat to check for open ports from the local machine. It relies on the netstat command being available via an SSH conn
credentials.
WMI (netstat)
When enabled, the scanner uses netstat to determine open ports while performing a WMI-based scan.
SNMP
When enabled, if the appropriate credentials are provided by the user, the scanner can better test the remote host and produce more detailed audit result
examining the version of the returned SNMP string. This information is necessary for these audits.
Only run network port scanners if local port enumeration failed
When enabled, the scanner relies on local port enumeration first before relying on network port scans.
Verify open TCP ports found by local port enumerators
When enabled, if a local port enumerator (for example, WMI or netstat) finds a port, the scanner also verifies that the port is open remotely. This approach
firewall).


Network Port Scanners
TCP
Override automatic firewall detection
Use soft detection
Use aggressive detection
Disable detection
SYN
Override automatic firewall detection
Use soft detection
Use aggressive detection
Disable detection
UDP
This option engages the built-in Nessus UDP scanner to identify open UDP ports on the targets. Due to the nature of the protocol, it is generally not possib
UDP port scanner may dramatically increase the scan time and produce unreliable results. Consider using the netstat or SNMP port enumeration options

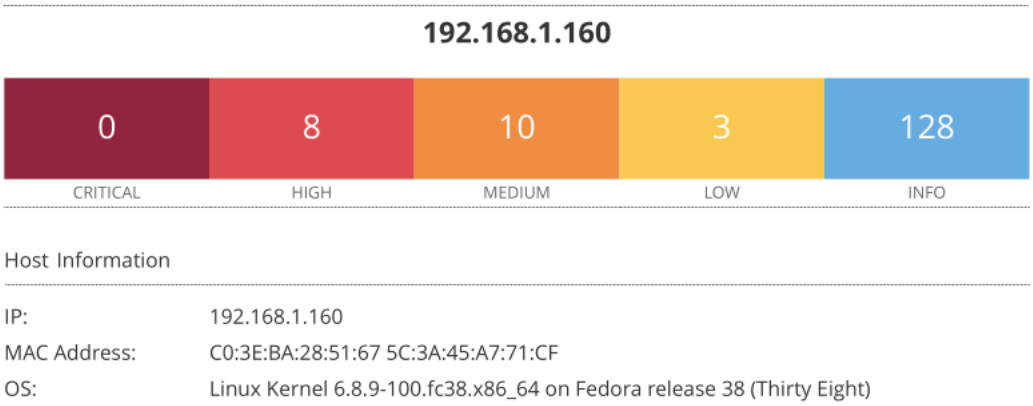

Settings
Credentials
Plugins
BASIC
DISCOVERY
Host Discovery
Port Scanning
Service Discovery
Identity
ASSESSMENT
REPORT
ADVANCED
General Settings
Probe all ports to find services
When enabled, the scanner attempts to map each open port with the service that is running on that port, as defined by the Port scan range option. Cautio
Search for SSL/TLS/DTLS services
ON
Controls how the scanner tests SSL-based services. Caution: Testing for SSL capability on all ports may be disruptive for the
Search for SSL/TLS on
All TCP ports
Search for DTLS on
None
Identify certificates expiring within x days
60
When enabled, the scanner identifies SSL and TLS certificates that are within the specified number o
Enumerate all SSL/TLS ciphers
When enabled, the scanner ignores the list of ciphers advertised by SSL/TLS services and enumerates them by attempting to establish connections usi
Enable CRL checking (connects to the Internet)
When enabled, the scanner checks that none of the identified certificates have been revoked.

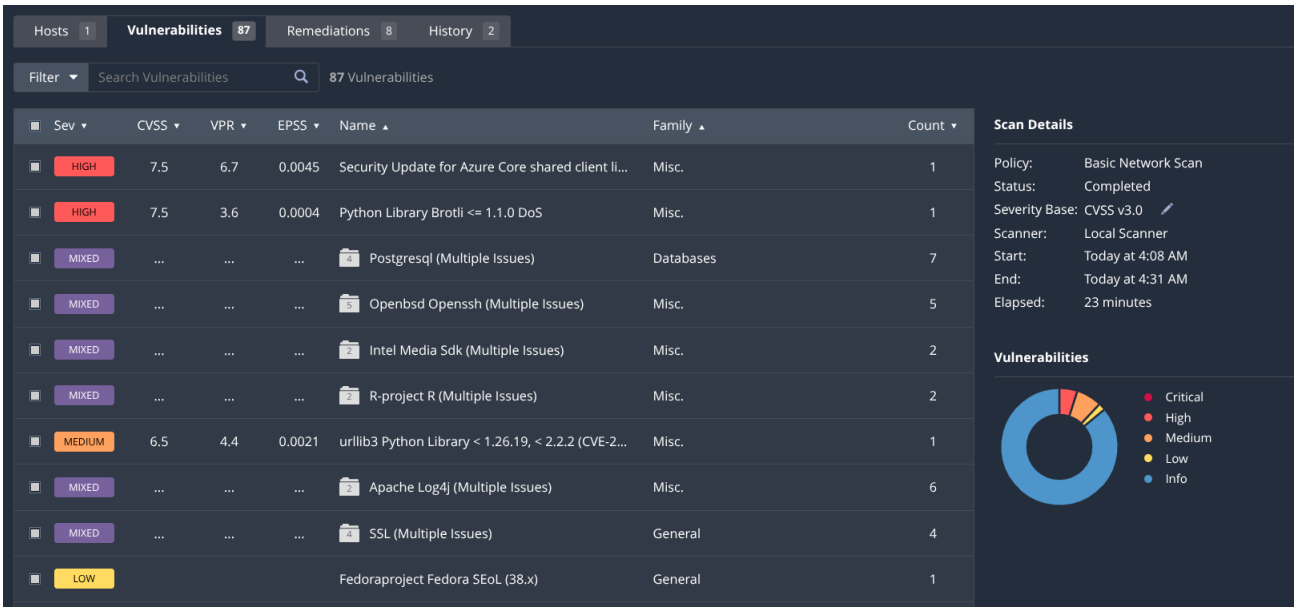

Settings
Credentials
Plugins
BASIC
DISCOVERY
ASSESSMENT
REPORT
ADVANCED
Processing
Override normal verbosity
I have limited disk space. Report as little information as possible
Report as much information as possible
Show missing patches that have been superseded
When enabled, includes superseded patch information in the scan report.
Hide results from plugins initiated as a dependency
When enabled, the list of dependencies is not included in the report. If you want to include the list of dependencies in the report, disable this setting.
Output
Allow users to edit scan results
When enabled, allows users to delete items from the report. When performing a scan for regulatory compliance or other types of audits, disable the settir
Designate hosts by their DNS name
Uses the host name rather than IP address for report output.
Display hosts that respond to ping
Reports hosts that successfully respond to a ping.
Display unreachable hosts
When enabled, hosts that did not reply to the ping request are included in the security report as dead hosts. Do not enable this option for large IP blocks.
Display Unicode characters
When enabled, Unicode characters appear in plugin output such as usernames, installed application names, and SSL certificate information. Note: Plugin
causes problems with regular expressions in plugins or custom audits, disable this setting and scan again.



Lo más destacado de este escaneo, es que se tiene un total de 8 vulnerabilidades Altas, 10 Medias y 3 Bajas. Estas vulnerabilidades se pueden agrupar de la siguiente forma:

- **Sistema Operativo**: El sistema Fedora 38 ha llegado a su fin de vida útil. Esta es la vulnerabilidad más importante, ya que significa que los repositorios oficiales ya no reciben parches de seguridad, lo que provocando lo mismo en el resto de tus paquetes.
- **Res y Bases de Datos**: OpenSSH (m)últiples vulnerabilidades incluyendo RCE y ataques MitM), PostgreSQL (Heap Buffer Overflow).
- **Entornos de desarollo y análisis de datos**: Python (bibliotecas desactualizadas), R (vulnerabilidad de deserialización), Apache e Intel Media SDK.
- **Certificado SSL**: Esto se detectó en el puerto 8834. Ese es el puerto del propio Nessus. Omitiremos está vulnerabilidad.



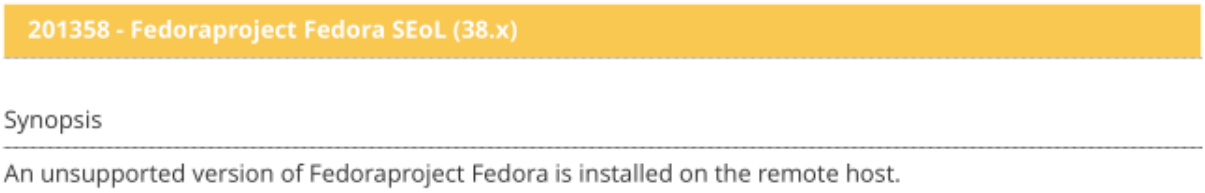


Los resultados detallados de este escaneo se encuentran en el archivo `Descubrimiento de Vulnerabilidades.pdf`

2.2. Soluciones a implementar

A continuación se realizan diferentes métodos para solucionar estas vulnerabilidades encontradas. Las agruparemos por software o servicio. Se usa Gemini para analizar las vulnerabilidades y encontrar la solución adecuada.

1. **Fedoraproject Fedora SEoL (201358)**



Fedora 38 llegó a su fin de vida en 2024, lo que significa que actualmente no recibe parches de seguridad ni actualizaciones de aplicaciones. La solución que se implementará, será actualizar el SO de Fedora 38 a Fedora 42 (última versión estable y soportada).

Para minimizar riesgos, la recomendación general es no saltar más de dos versiones a la vez, por lo se instala primero Fedora 40, para luego instalar Fedora 42.

a) Primero, actualizamos lo más posible la versión actual:

```
sudo dnf upgrade --refresh
```

b) Descargaremos los paquetes para la versión 40. Usaremos –allowerasing para que el gestor resuelva conflictos eliminando paquetes antiguos si es necesario:

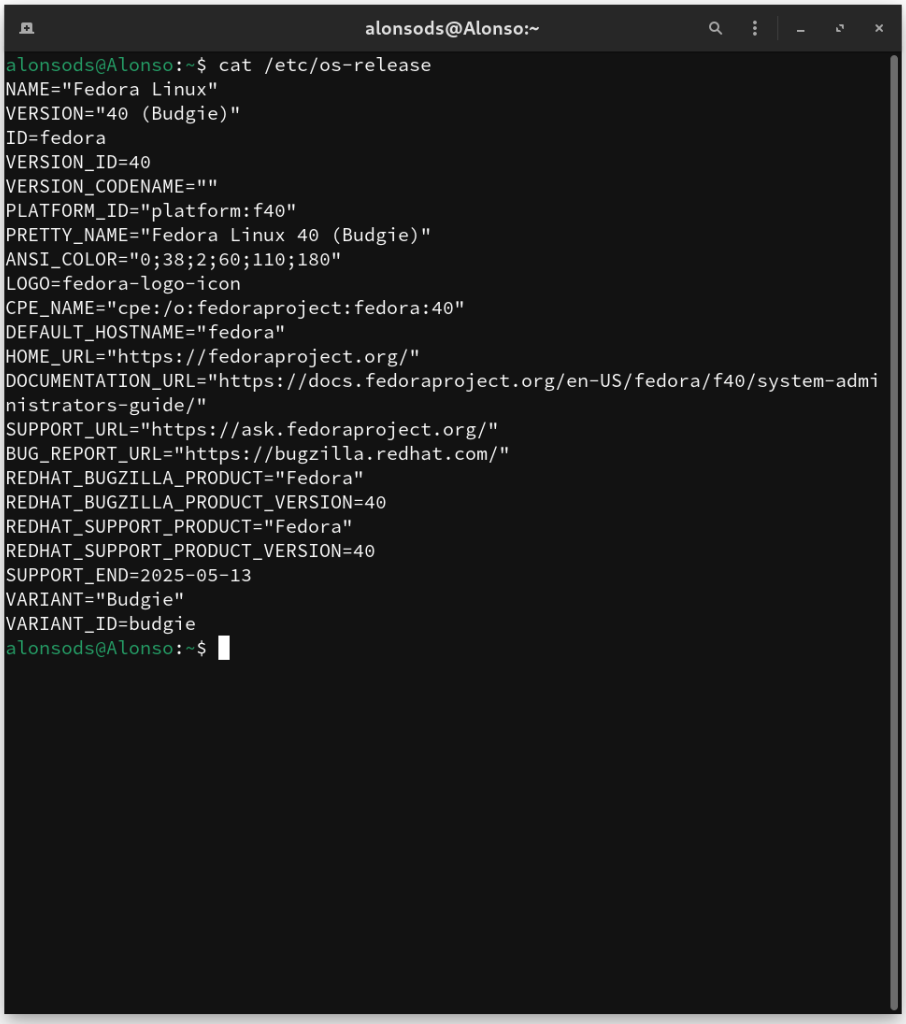
```
sudo dnf system-upgrade download --releasever=40 --allowerasing
```

c) Ejecutamos el reinicio y actualización:

```
sudo dnf system-upgrade reboot
```

d) Verificamos la versión:

```
cat /etc/fedora-release
```



e) Limpiamos archivos restantes de la descarga anterior y liberamos espacio:

```
sudo dnf system-upgrade clean
sudo dnf clean all
```

f) Ahora repetiremos todos los pasos anteriores en ese mismo orden, cambiando solo el número de versión:

```
sudo dnf system-upgrade download --releasever=42 --allowerasing
```



2. **OpenSSH (201194, 187201, 234554, 269984)**



187201 - OpenSSH < 9.6 Multiple Vulnerabilities

Synopsis

The SSH server running on the remote host is affected by multiple vulnerabilities.

51192 - SSL Certificate Cannot Be Trusted

Synopsis

The SSL certificate for this service cannot be trusted.

234554 - OpenSSH < 10.0 DisableForwarding

Synopsis

The SSH server running on the remote host is affected by a vulnerability.

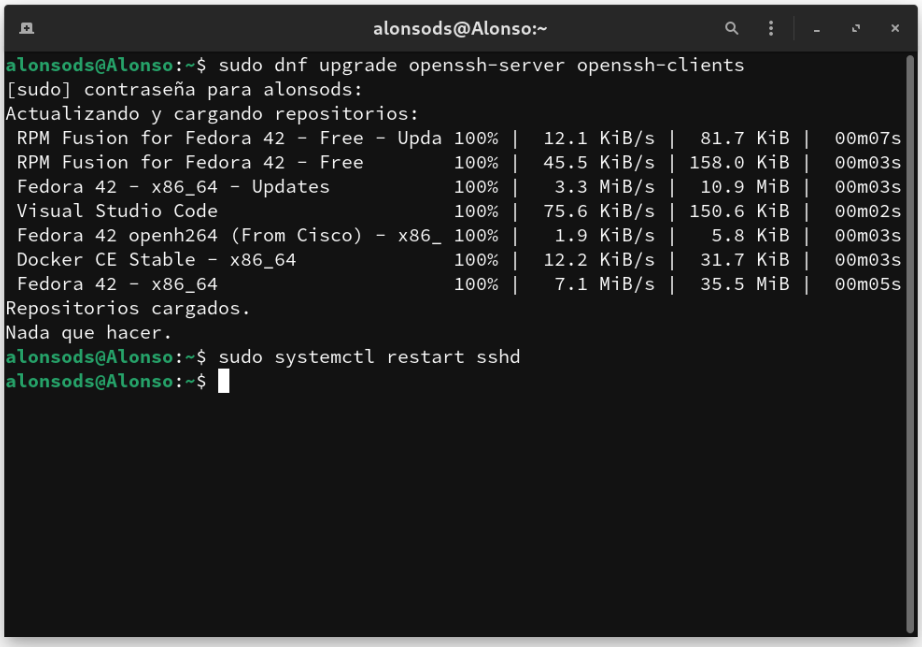
269984 - OpenSSH < 10.1 / 10.1p1 Multiple Vulnerabilities

Synopsis

The SSH server running on the remote host is affected by multiple vulnerabilities.

Se tiene versiones vulnerables. Nessus recomienda llegar a la versión 10.1. La solución es actualizar los archivos del servidor SSH y reiniciar el servicio para que cargue la nueva versión en memoria.

```
sudo dnf upgrade openssh-server openssh-clients
sudo systemctl restart sshd
```



3. **PostgreSQL (299758, 299757, 275842)**

299758 - PostgreSQL 14.x < 14.21 / 15.x < 15.16 / 16.x < 16.12 / 17.x < 17.8 / 18.x < 18.2 Multiple Vulnerabilities

Synopsis

The remote database server is affected by multiple vulnerabilities.

299757 - PostgreSQL 18.x < 18.2 Heap Buffer Overflow (CVE-2026-2007)

Synopsis

The remote database server is affected by a heap buffer overflow vulnerability.

275842 - PostgreSQL 13.x < 13.23 / 14.x < 14.20 / 15.x < 15.15 / 16.x < 16.11 / 17.x < 17.7 / 18.x < 18.1 Multiple Vulnerabilities

Synopsis

The remote database server is affected by multiple vulnerabilities

Se encontraron múltiples vectores de desbordamiento de memoria (Heap Buffer Overflow) y vulnerabilidades de denegación de servicio asociadas a las extensiones y funciones del cliente

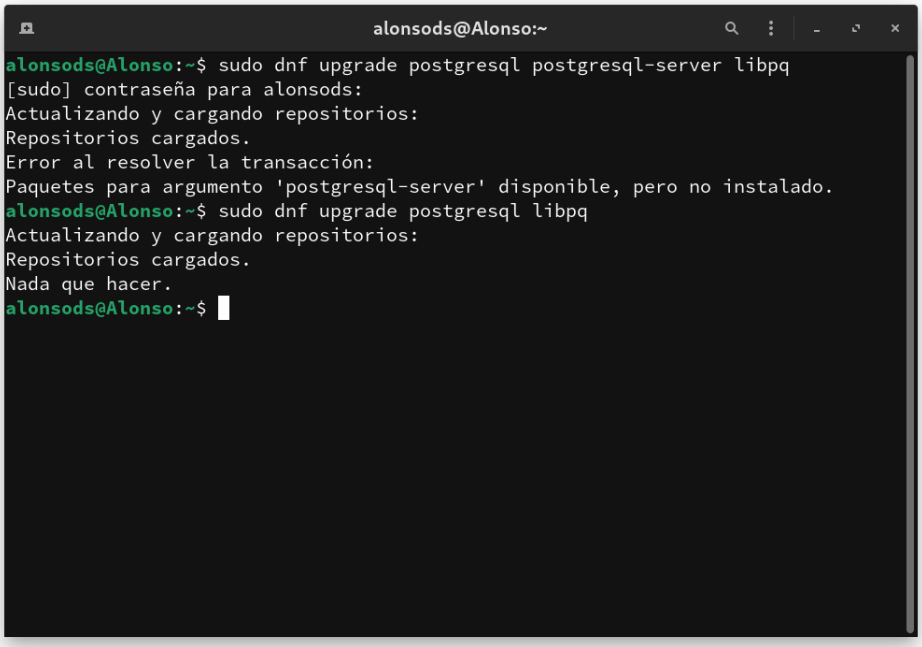
`libpq`. La solución es actualizar la base de datos y sus librerias:

```
sudo dnf upgrade postgresql postgresql-server libpq
```

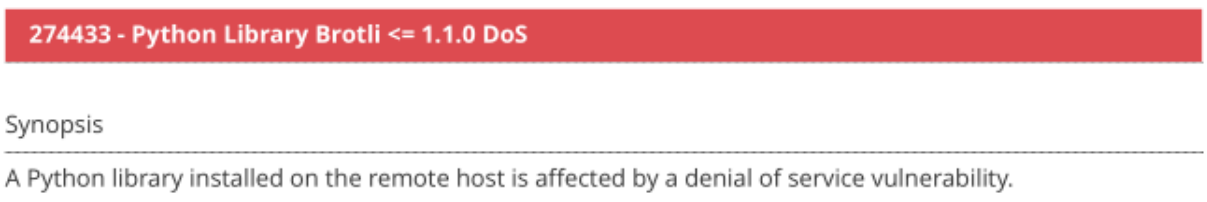
Sin embargo al ejecutar el comando, el gesto `dnf` nos menciona que queremos actualizar `upgrade` al parque `postgresql-server` pero ese paquete ya no existe. ¿Entonces porqué se marcó como vulnerabilidad? Nessus es muy minucioso, por lo que pudo haber detectado las librerías cliente de PostgreSQL que se instalan como dependencias para otros programas. Nessus leyó la versión y lanzó alerta.

Dado que el servidor no está instalado, simplemente lo omitimos de la actualización. Ejecuta el comando solo con los paquetes existentes:

```
sudo dnf upgrade postgresql libpq
```



4. **Python:** `brotli`, `urllib3`, **azure-core (274433, 200807, 283875)**



282519 - Apache Log4j 2.0-beta9 < 2.25.3 MitM

Synopsis

A logging library installed on the remote host is affected by a man in the middle vulnerability.

200807 - urllib3 Python Library < 1.26.19, < 2.2.2 (CVE-2024-37891)

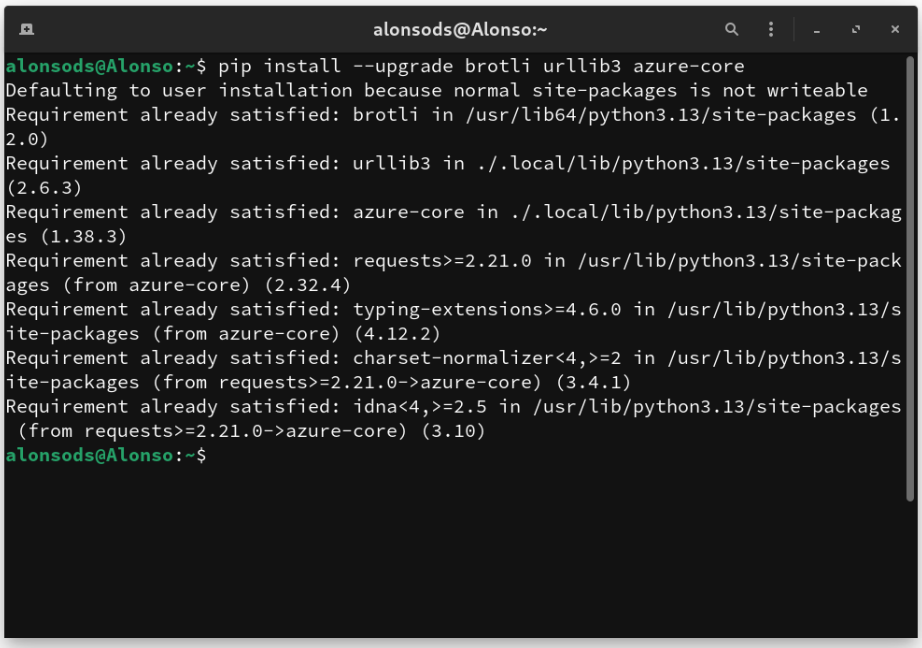
Synopsis

A Python library installed on the remote host is affected by a vulnerability.

Riesgos de denegación de servicio (DoS) por compresión en brotli, cabeceras proxy mal manejadas en urllib3 y escalada de privilegios en el SDK de Azure.

Dado que estos suelen gestionarse a través de Python, lo ideal es usar `pip` para forzar la actualización a las versiones seguras que pide Nessus (ej. brotli 1.2.0+, urllib3 2.2.2+). Realizamos el siguiente comando:

```
pip install --upgrade brotli urllib3 azure-core
```



5. **Intel Media SDK (197900)**

Vulnerabilities

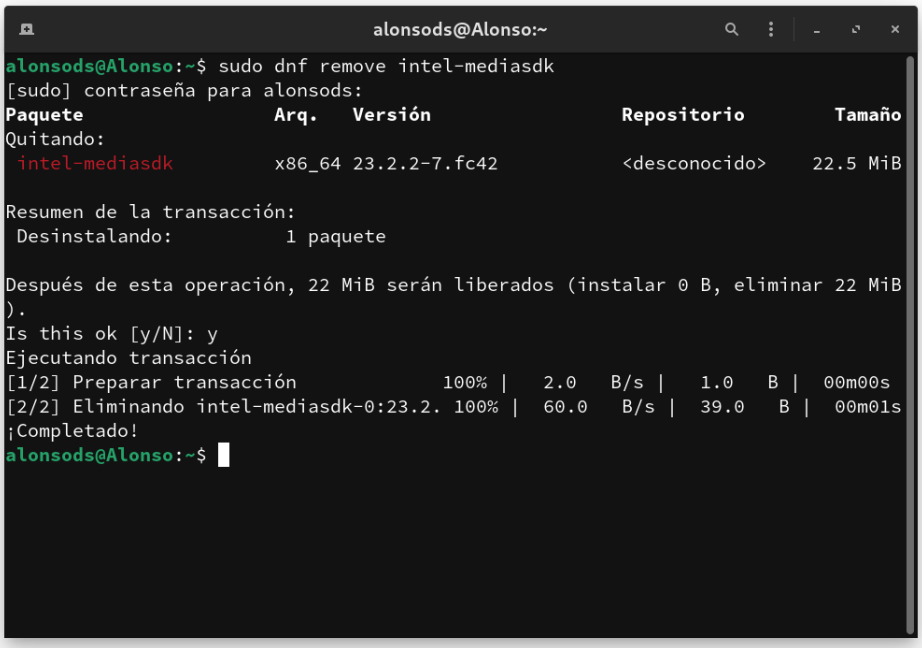
197900 - Intel Media SDK Multiple Vulnerabilities (INTEL-SA-00935)

Synopsis

The version of Intel Media SDK installed on the remote host is affected by multiple vulnerabilities.

Múltiples fallos de lectura/escritura fuera de límites y validación de entrada. En particular, el paquete intel-mediasdk (que contiene librerías como libmfx) es un kit de desarrollo de software creado por Intel. Su propósito era permitir que las aplicaciones aprovecharan la aceleración por hardware (Intel Quick Sync Video) para codificar, decodificar y procesar video. Intel descontinuó oficialmente este SDK. De hecho, la propia recomendación de seguridad de Intel para estas vulnerabilidades es desinstalarlo, ya que lo reemplazaron por una tecnología más moderna llamada Intel oneVPL. Por lo cual procedemos a desinstarlo:

```
sudo dnf remove intel-mediasdk
```



6. **Certificado SSL no confiable en puerto 8834 (51192)**

51192 - SSL Certificate Cannot Be Trusted

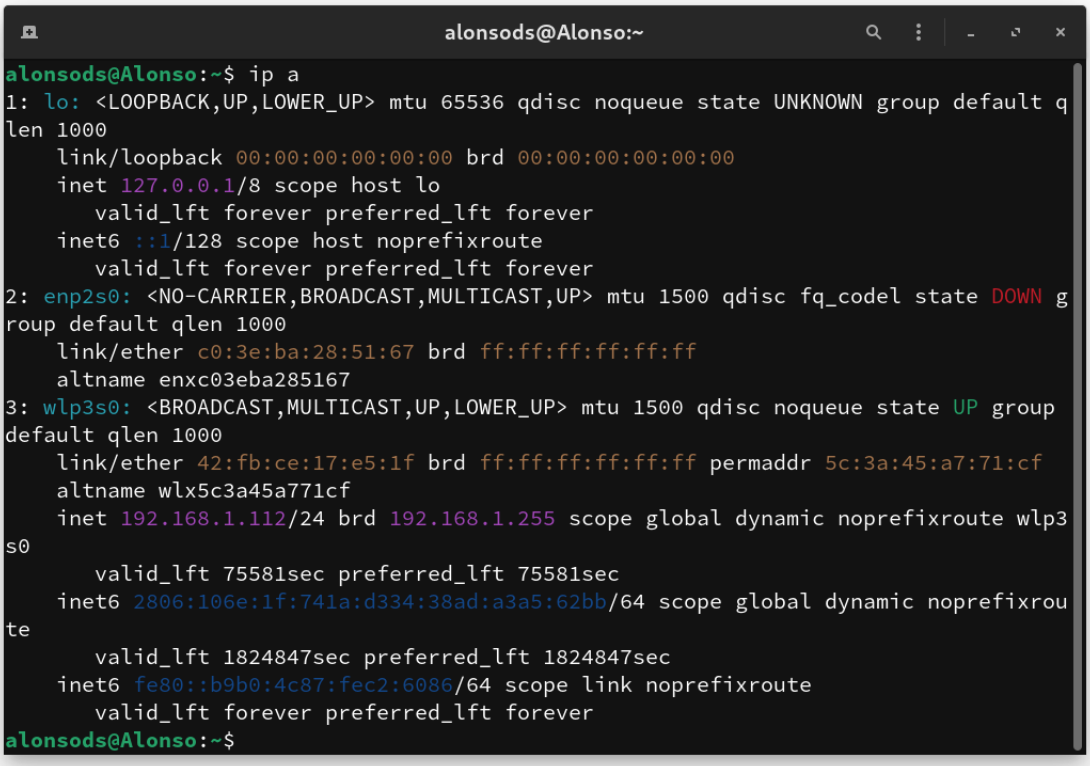
Synopsis

The SSL certificate for this service cannot be trusted.

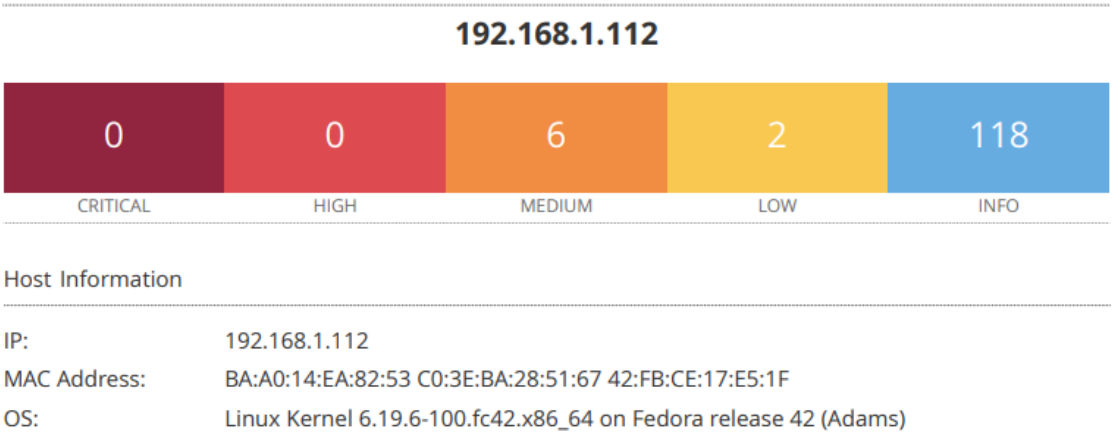
El puerto 8834 es el que utiliza el propio Nessus Essentials. Al instalarlo, generó un certificado "autofirmado"para poder ofrecer acceso por HTTPS en localhost. Como no fue emitido por una entidad certificadora global, Nessus se detecta a sí mismo como inseguro. Por lo tanto, no hay soluciones que implementar.

2.3. Segundo escaneo

Cuando se hizo la actualización del sistema operativo de Fedora 38 a Fedora 42, ocurrió un cambio de IP local. La interfaz de red se reinició, y el router le asignó a la computadora una nueva dirección IP: `192.168.1.112`.



Por lo tanto, actualizamos el objetivo a Nessus y ejecutamos un nuevo escaneo.



Los resultados detallados de este escaneo se encuentran en el archivo `Descubrimiento de Vulnerabilidades (Post-medidas).pdf`

3. Vulnerabilidad: CVE-2014-0160

Esta es una de las vulnerabilidades más conocidas de la historia de la ciberseguridad. Su nombre es "Heartbleed" (hemorragia de corazón). Afectó a la biblioteca criptográfica OpenSSL, específicamente a la implementación de la extensión "Heartbeat"(Latido de corazón) de TLS/DTLS. Sus parámetros CVSS son:

- Puntuación CVSS v2: 5.0 (Media). Aunque la industria la trata como crítica por su facilidad de explotación.
- Vector de Acceso (AV): Red (Network). El atacante puede explotarla remotamente desde internet.
- Complejidad de Acceso (AC): Baja. Es trivial de explotar; no requiere condiciones especiales en el sistema.
- Autenticación (Au): Ninguna. El atacante no necesita credenciales para explotarla.
- Impacto de Confidencialidad (C): Parcial.
- Impacto de Integridad y Disponibilidad: Ninguno. El ataque no modifica ni tira el servicio, solo lee datos sigilosamente.

La falla consistía en un error de comprobación de límites (Buffer Over-read). Un atacante enviaba

un mensaje al servidor engañándolo sobre el tamaño del mensaje. El servidor, al responder, devolvía el mensaje original más un fragmento de su propia memoria RAM (hasta 64 kilobytes por intento). Su manera de ataque es filtrar claves privadas maestras X.509 del servidor, nombres de usuario, contraseñas en texto plano, cookies de sesión de los usuarios conectados y correos electrónicos que estuvieran pasando por la RAM en ese momento.

Comprometió la seguridad de casi el 20 % de los servidores web seguros de todo internet en 2014, obligando a revocar masivamente certificados SSL y a los usuarios a cambiar sus contraseñas en plataformas globales.